

ISO 27001 Incident Management Report

SQL Injection Vulnerability in DVWA

Introduction

This report aims to document the detection, analysis and exploitation of a SQL Injection vulnerability within a controlled environment such as Damn Vulnerable Web Application (DVWA). This activity seeks to understand and demonstrate how poor input validation can compromise a web system. The process included the installation of the environment up to the execution of the attack, as well as the resolution of technical problems related to the database configuration.

Incident Description

In the security tests performed on the DVWA application, a major vulnerability was identified in the SQL Injection module. This weakness allows an attacker to inject SQL commands through the user ID input field, which could compromise both the confidentiality and integrity of the data stored in the database.

Before the vulnerability could be exploited, a problem was detected in the permissions of the *root* user in MySQL. This error prevented the connection between DVWA and the database, and gave the message:

Access denied for user 'root'@'localhost'

The solution to this problem was to set the *config.inc.php* file with the correct credentials and give it the right permissions in MySQL.

Process description

- **Phase 1:** Proceed with the installation of DVWA in a Linux environment, in this case a Kali virtual machine.
- **Phase 2:** Check that Apache and MySQL are active and configure them.
- **Phase 3:** Resolving possible errors in this case, the permissions for the root user.
- **Phase 4:** Assigning user permissions with:

```
sudo chown -R www-data:www-data /var/www/html/DVWA/  
sudo chmod -R 755 /var/www/html/DVWA/
```

In turn assign permissions to root with:

```
GRANT ALL PRIVILEGES ON DVWA.* TO 'root'@'localhost' IDENTIFIED  
BY 'kali';  
FLUSH PRIVILEGES;
```

- **Phase 5:** Access at <http://localhost/DVWA/setup.php>, where a page is displayed and the database is created from the interface.
- **Phase 6:** Access to the “SQL Injection” module found in the platform.
- **Phase 7:** Injection of the following string in the user ID field:

1' OR '1'='1

- **Phase 8:** Obtaining multiple results from users stored in the database, demonstrating that the application is vulnerable to SQL Injection.

Incident Impact

The exploitation of this vulnerability allowed:

- Access to sensitive information of all users stored in the database.
- Perform unauthorized queries that could be extended to modify or delete critical data.
- Expose user names and internal database structures.

If this were a real scenario this vulnerability exploitation may constitute a legal violation of the GDPR if personal data is compromised. Breaching RGPD / LOPDGDD Articles number 5, 25, 32, 33.

Breaking into the processing, security and protection of data and information security management.

Suggestions

1. **Input validation:** Use prepared statements or parameterized queries to prevent injections.
2. **Error handling:** Configure the application so that it does not display detailed database errors to the user.
3. **Security testing:** Run vulnerability scans and pentesting on a regular basis.

4. **Principle of privilege:** Avoid using the root user in web applications. Instead a limited user could be created only for reading and/or writing to the specific database.
 5. **Training:** Train developers in safe coding and incident management practices.
-

Summary

The DVWA exercise demonstrated how it can be possible to exploit a SQL injection vulnerability to gain unauthorized access to sensitive information. It also made clear how inattention to detail, such as granting too much access to certain users with respect to the database, can pose a serious security risk.

This incident demonstrates how appropriate protective measures must be imposed from the earliest stages of software development, along with the need for ongoing reviews to ensure system integrity.

In a real environment, this exploit could be considered a violation of data protection laws such as the Organic Law on Data Protection and Guarantee of Digital Rights (LOPDGDD) as well as the General Data Protection Regulation (GDPR). Since it violates fundamental principles of confidentiality and data integrity, in addition to breaching legal obligations associated with the security of the data processed.

That is why it is of utmost importance to understand that technical failures are not only an operational risk, but also a legal and reputational risk for any entity.